

Planning your certificate environment

The following questions and answers represent decisions on which you will base your z/OS certificate environment.

What is the name of my network entity?

When creating a certificate, the subject name in the certificate is the name of the entity it represents. The subject's name is an X.500 distinguished name that consists of various qualifier-value pairs. For example, if you are creating a certificate for a Web server with the domain name systems.abc.com within the Systems division of a company in the United States, the distinguished name might be as follows: CN=systems.abc.com, OU=Systems Division, O=ABC, C=US.

What type of encryption will I choose for my public and private key pair?

RSA is the default. Choose DSA only when you have a specific need for DSA.

Which user ID will be the owner of my certificate?

The user ID of the daemon or started task associated with your application will be the owner of the certificate.

What nickname or label will this certificate to be known by?

A certificate label can be up to 32 characters in length and must be unique to each owning user ID.

How big will my private key be?

The larger the key, the greater its strength and the slower it operates. Be aware that some larger keys might be export-controlled.

Where will I generate and store my private key?

RACF gives you the ability to generate keys in hardware or software. Keys generated by Integrated Cryptographic Service Facility (ICSF) hardware are more secure but require that the hardware is always present and enabled. (RACF cannot back up ICSF keys.) By contrast, keys generated and stored as software keys are least secure. This is because they are stored in the RACF database in a masked format that is less secure than being encrypted by ICSF. The best

compromise is to generate your keys in software, save them to an encrypted PKCS #12 data set, and then store them in ICSF.

Which organization will issue my certificate? Who will be my certificate authority?

If you intend to operate a commercial Web application, choose a well-known commercial certificate authority. If you have no need for a well-known certificate authority and need only a small number of certificates, choose RACF as a small-scope certificate authority. If you need to issue a large number of certificates, consider using commercial software, such as z/OS Cryptographic Services PKI Services. (To find out more about PKI Services, see z/OS Cryptographic Services PKI Services Guide and Reference.)

Will I specify a certificate validity period?

If you plan to create a certificate that you will not replace with an externally signed one, then you should specify the validity period. RACF's default validity period is one year from the date of issue but this period is usually not long enough for a CA certificate. If you request a certificate from an external certificate authority, you need not specify the validity period. The external certificate authority sets the validity period.

Which certificate authorities will I trust?

You need to decide which certificate authorities you will consider trusted enough to identify parties involved in the network protocol with your application. You need to trust at least one certificate authority, the one that issued the certificate for your application. Any others you choose are based on the needs of your application and its users. The set of certificate authorities that your application considers trusted comprise your application's trust policy, or RACF key ring.

Setting up your certificate environment

After you complete your planning decisions, you can begin setting up your z/OS certificate environment. In general, this is the sequence of activity involved in preparing for one entity, or application, to use a secure network protocol. All of the following activities are described using RACF command functions where applicable. (For RACDCERT command syntax, see z/OS Security Server RACF Command Language Reference.) At your option, you can choose to supplement your activities with support from other software or external organizations.

If you chose RACF as your certificate authority, use the RACDCERT GENCERT command to generate your certificate authority (CA) certificate, the associated public, and the private key pair in RACF. Set the certificate's validity period because the one-year default value is usually not long enough for a CA certificate.

Use the RACDCERT GENCERT command to generate your application's end-entity certificate, and the associated public and private key pair, in RACF.

If you are using RACF as your certificate authority, sign the application certificate with your RACF certificate authority certificate.

If you are using an external certificate authority, create a self-signed certificate in RACF as a placeholder and use the RACDCERT GENREQ command to generate a certificate request, based on the placeholder certificate, to send to your external certificate authority. The certificate request (header line, footer line, and all data between them) is sent to the certificate authority who signs the certificate and returns it to you. Upon receipt, use RACDCERT ADD to replace the self-signed certificate with your new CA-signed certificate.

If you peek at a request data set before you send it to the certificate authority, you will notice the following header and footer lines. (Certificate requests are always DER-encoded and then base64-encoded, like base64-encoded certificates.)

-----BEGIN NEW CERTIFICATE REQUEST-----

.
.
.

-----END NEW CERTIFICATE REQUEST-----

Establish the trust policy for your application. (For details, see RACF and key rings.)

Use the RACDCERT ADDRING command to define a key ring in RACF and associate it with your application's user ID.

Use the RACDCERT CONNECT command to connect certificates to the key ring. Be sure to connect your trusted certificate authority certificates and the certificate that represents your application.